

ISO 27001: How It Works, Benefits, and How to Certify

What Is ISO 27001?

ISO/IEC 27001 is an information security management standard that specifies how companies manage the risks associated with information security threats. Includes policies, procedures and employee training.

ISO/IEC 27001 is jointly issued by the International Organization for Standardization and the International Electrotechnical Commission. It defines an accredited standard that demonstrates commitment to information security management through information security guidelines, requirements designed to protect an organization's data assets from loss or unauthorized access, and certification.

ISO 27001 includes risk assessment processes, organizational structure, information classification, access control mechanisms, physical and technical security measures, information security policies, procedures, monitoring and reporting guidelines.

This is part of a series of articles about [security compliance](#).

What Is an Information Security Management System (ISMS)?

An Information Security Management System (ISMS) is a set of policies and procedures for systematically managing an organization's sensitive data. The goal of ISMS is to proactively limit the impact of a security breach to minimize risk and ensure business continuity.

ISMS typically includes employee behaviors and processes, data and skills. It can target specific types of data, such as customer data, or it can be implemented in an inclusive way to become part of the corporate culture.

ISMS provides a systematic approach to managing the security of organizational information. Information security includes specific broad strategies for controlling and managing the level of security risk across an organization.

How Does ISO 27001 Work?

The focus of ISO 27001 is to protect the confidentiality, integrity and availability of information within an enterprise. This includes identifying potential problems with the information (risk assessment) and actions that must be taken to prevent them from occurring (risk mitigation).

In general, the standard focuses on defining the risk management process. Practically, this involves identifying where there is a risk and implementing security controls to address it systematically. ISO 27001 requires companies to document all controls they have implemented in a document called a Statement of Applicability.

ISO 27001 Clauses

The latest revision of ISO 27001 from 2013 includes 11 clauses (including "0") and an annex listing specific controls. Each clause contains several sub-clauses (except the introduction). The first three clauses are optional, and the rest are mandatory (required to achieve compliance).

The clauses are:

- **Introduction**—defines the standard's purpose.
- **Scope**—provides an overview of the requirements detailed in the standard. It explains that the standard is generic and relevant to many industries and businesses.
- **Normative references**—this clause describes the relationship between ISO 27001 and ISO 27000.
- **Terms and definitions**—establishes the terminology used in the standard.
- **Organization context**—addresses stakeholders, external and internal security issues, and compliance requirements (the first "mandatory" clause).
- **Leadership**—addresses senior executive's support for ISO 27001 compliance, explaining the responsibilities of top management.
- **Planning**—addresses risk assessment and management. It stipulates creating objectives to measure ISMS performance. Organizations must define their criteria for risk assessments, analysis, and treatment.
- **Support**—addresses the required resources for implementing and supporting an ISMS.
- **Operation**—explains how organizations can put their plans into action.
- **Evaluating performance**—addresses the need to measure the performance of the ISMS and maximize security. It includes requirements for monitoring and evaluating security

policies, controls, and procedures, including internal auditing and reviews.

- **Improvement**—addresses failure to conform to the previous clauses and provides guidelines for continuously improving the information security system.

ISO 27001 Controls

Aside from the clauses, Annex A describes security controls to facilitate compliance with the standard's requirements. Types of controls include:

- **Information security policies**—ensure policies are in line with organizational security objectives and practices.
- **Organizing information security**—assign responsibilities for each task.
- **Human resources**—ensure employees understand their obligations.
- **Asset management**—identify your information assets and establish relevant security responsibilities.
- **Access controls**—ensure employees can only view relevant information.
- **Cryptographic controls**—maintain data integrity and confidentiality.
- **Physical controls**—prevent unauthorized access to data, equipment, and premises.
- **Communication controls**—protect networks and data.
- **Supplier relationship management**—manage contracts with third parties.
- **Information security incident management**—manage and report security incidents effectively.
- **Business continuity management**—minimize business disruptions.
- **Compliance controls**—ensure compliance with relevant regulations and laws.

Related content: [Read our guide to ISO 27001 checklist](#)

The Benefits of ISO 27001 Compliance

Here are three key benefits of ISO 20001:

Improving Security Practices

Compliance with the ISO 27001 standard strengthens an organization's security posture. Identifying and remediating risks, and defining people and processes responsible for risk management, can reduce vulnerability to security incidents and also lessen their impact when they occur. This can help organizations avoid the high costs of incident response, data recovery, loss of business and reputation, and regulatory fines.

Assisting with Regulatory Compliance

ISO 27001 is a global standard which has been used as a basis for many international data privacy laws. For example, the GDPR refers covered entities to the ISO 27001 standard, and Australia's Digital Security Policy is intentionally created to comply with ISO 27001.

While ISO 27001 certification does not guarantee full compliance with all data security regulations, it represents a big step in the right direction to achieve data privacy compliance goals.

Establishing Accountability

Another benefit of ISO 27001 is that it requires organizations to establish accountability for information risk. This transparent chain of command helps clarify roles and processes and maintain proper access controls as information assets grow.

How to Obtain ISO 27001 Certification

The ISO 27001 certification process can take a long time, sometimes more than a year. ISO itself does not issue ISO 27001 certification—instead, independent auditors of accredited certification bodies verify that the company has successfully applied all required best practices in accordance with established ISO standards.

Because this structure and framework focuses on risk management rather than essential technical controls, a comprehensive ISO 27001 compliance checklist cannot guarantee certification. Each company is free to choose how to implement the framework, and auditors use their professional judgment to evaluate each situation.

When a company is ready to hire an auditor or certification body, it must go through a series of steps to get certified:

- **High-level audit**—an external auditor or certification body performs a high-level audit of the organization's ISMS. This step ensures that your organization is ready for the second, more detailed step. ISO 27001 audits can fail due to lack of critical documentation, lack of management support, or misinterpretation of indicators.
- **Comprehensive audit**—conduct a more thorough audit that examines your organization's implementation of specific security procedures to meet the outlined standards. At this stage, the auditor looks for evidence that the company has performed all the actions described in the documents provided in the first stage.
- **Follow up audits**—officially accredited companies are required to undergo annual follow-up audits to maintain compliance with ISO 27001. ISO 27001 certification may be revoked

prior to the specified expiration date if the annual follow-up audit discovers significant information security risks.

ISO 27001 Management with HackerOne

HackerOne is ISO 27001 certified and operates our business at the highest level of information security accountability. Our CISO and compliance team has put in place policies, procedures and regular training to assure that the entire company is working together to ensure information safety. This certification provides a secure foundation that underpins our platform and product portfolio so our customers have confidence in HackerOne as a trusted security partner.

[Learn more about HackerOne Trust](#)

Company

Leadership

Careers

Partners

Newsroom

Contact Us

Knowledge

Center

Application Security

Penetration Testing

Cloud Security

Hacking

Cybersecurity

Attacks

DevSecOps

Resources

Blog

Documentation

Leaderboard

Partner Portal

Resources

Contacted
by a
hacker?

